

Lekcja 8 - Wireshark i analiza ruchu – Homework

Zakres materiału:

- nazwa i SHA-256 pliku:
- źródło i punkt przechwycenia:
- przedział czasu i strefa:
- znane ograniczenia:

Podsumowanie:

- 2–3 zdania opisujące najważniejszy wynik i jego znaczenie.

Chronologia:

- czas — źródło:port -> cel:port — obserwacja
- czas — źródło:port -> cel:port — obserwacja

Dowody:

- numer ramki lub strumienia:
- zastosowany filtr:
- zaobserwowane pola i statystyki:

Ocena:

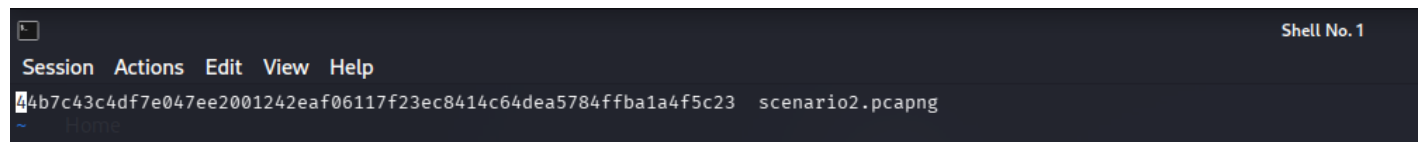
- hipoteza:
- alternatywne wyjaśnienie:
- poziom pewności: niski / średni / wysoki

Rekomendowane działania:

- korelacja z logami lub EDR,
- identyfikacja właściciela i procesu,
- ewentualna izolacja zgodnie z procedurą IR.

Zadanie nr 2

nazwa i SHA-256 pliku:

A screenshot of a terminal window with a dark background. The title bar at the top right says "Shell No. 1". The terminal shows a command prompt with a tilde (~) and the word "Home" in blue. The command entered is "44b7c43c4df7e047ee2001242eaf06117f23ec8414c64dea5784ffba1a4f5c23 scenario2.pcapng". The output of the command is the same long hexadecimal string: "44b7c43c4df7e047ee2001242eaf06117f23ec8414c64dea5784ffba1a4f5c23".

```
~ Home  
44b7c43c4df7e047ee2001242eaf06117f23ec8414c64dea5784ffba1a4f5c23 scenario2.pcapng  
44b7c43c4df7e047ee2001242eaf06117f23ec8414c64dea5784ffba1a4f5c23
```

44b7c43c4df7e047ee2001242eaf06117f23ec8414c64dea5784ffba1a4f5c23

Scenario2.pcapng

Naniosłem filtr w Wiresharku w celu wykrycia prób połączeń TCP:

“tcp.flags.syn == 1 and tcp.flags.ack == 0”

tcp.flags.syn == 1 and tcp.flags.ack == 0							
No.	Time	Source	Destination	Protocol	Length	Info	
128	9.101529	192.168.10.51	162.213.33.50	TCP	74	59051 → 443 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=3067288 TSecr=0 WS=128	
744	19.225543	192.168.10.16	192.168.10.50	TCP	74	41572 → 21 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=2983217 TSecr=0 WS=128	
745	19.225547	192.168.10.16	192.168.10.50	TCP	74	[TCP Retransmission] 41572 → 21 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=2983217 TSecr=0 WS=128	
776	19.334599	192.168.10.16	192.168.10.50	TCP	74	35392 → 21875 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=2983248 TSecr=0 WS=128	
777	19.346893	192.168.10.10	192.168.10.50	TCP	74	[TCP Retransmission] 35392 → 21875 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=2983248 TSecr=0 WS=128	
847	21.063347	192.168.10.51	162.213.33.50	TCP	74	59052 → 443 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=3070278 TSecr=0 WS=128	
864	22.060294	192.168.10.51	162.213.33.50	TCP	74	[TCP Retransmission] 59052 → 443 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=3070528 TSecr=0 WS=128	
881	22.745809	192.168.10.16	172.217.6.238	TCP	74	34118 → 443 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=2984097 TSecr=0 WS=128	
904	22.856553	192.168.10.16	172.217.11.14	TCP	74	38988 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=2984125 TSecr=0 WS=128	
957	23.006825	192.168.10.16	172.217.10.110	TCP	74	52070 → 443 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=2984183 TSecr=0 WS=128	
1060	23.810891	192.168.10.8	52.219.4.112	TCP	66	4865 → 443 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=4 SACK_PERM	
3156	27.612603	192.168.10.14	40.70.221.249	TCP	66	53040 → 443 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4236	43.437529	192.168.10.15	192.168.10.50	TCP	66	53872 → 22 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4237	43.437532	192.168.10.15	192.168.10.50	TCP	66	[TCP Retransmission] 53872 → 22 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4304	44.037609	192.168.10.14	23.194.109.216	TCP	66	53041 → 80 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4368	44.038312	192.168.10.14	23.194.182.63	TCP	66	53042 → 80 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4369	44.038388	192.168.10.14	23.194.182.63	TCP	66	53043 → 80 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4406	44.889014	192.168.10.15	192.168.10.50	TCP	66	53873 → 22 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4407	44.889017	192.168.10.15	192.168.10.50	TCP	66	[TCP Retransmission] 53873 → 22 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4506	48.203904	192.168.10.15	205.174.165.73	TCP	66	53874 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4509	48.716365	192.168.10.15	205.174.165.73	TCP	66	[TCP Port numbers reused] 53874 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4512	49.216379	192.168.10.15	205.174.165.73	TCP	62	[TCP Port numbers reused] 53874 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 SACK_PERM	
4522	49.413574	192.168.10.5	104.90.88.218	TCP	66	52326 → 80 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM	
4523	49.415513	192.168.10.8	205.174.165.73	TCP	66	4866 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=4 SACK_PERM	
4533	49.928595	192.168.10.8	205.174.165.73	TCP	66	[TCP Port numbers reused] 4866 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=4 SACK_PERM	
4535	50.427768	192.168.10.8	205.174.165.73	TCP	62	[TCP Port numbers reused] 4866 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 SACK_PERM	
4537	50.750303	192.168.10.5	192.168.10.3	TCP	66	52327 → 445 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4538	50.750306	192.168.10.5	192.168.10.3	TCP	66	[TCP Retransmission] 52327 → 445 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4629	55.699235	192.168.10.14	205.174.165.73	TCP	66	53044 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4635	56.192258	192.168.10.14	205.174.165.73	TCP	66	[TCP Port numbers reused] 53044 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4639	56.565736	192.168.10.5	205.174.165.73	TCP	66	53874 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4641	56.692784	192.168.10.14	205.174.165.73	TCP	62	[TCP Port numbers reused] 53044 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 SACK_PERM	
4657	56.886680	192.168.10.9	205.174.165.73	TCP	66	6434 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4665	57.158628	192.168.10.5	205.174.165.73	TCP	66	[TCP Port numbers reused] 52328 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4667	57.395803	192.168.10.9	205.174.165.73	TCP	66	[TCP Port numbers reused] 6434 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4669	57.654877	192.168.10.5	205.174.165.73	TCP	62	[TCP Port numbers reused] 52328 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 SACK_PERM	
4677	57.910603	192.168.10.9	205.174.165.73	TCP	62	[TCP Port numbers reused] 6434 → 8080 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 SACK_PERM	
4679	58.505206	192.168.10.14	192.168.10.3	TCP	66	53045 → 445 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4680	58.505210	192.168.10.14	192.168.10.3	TCP	66	[TCP Retransmission] 53045 → 445 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	
4732	58.614037	192.168.10.9	192.168.10.50	TCP	66	6435 → 22 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM	

Sprawdźitem również statystyki: "Endpoints":

Wireshark - Endpoints - scenario2.pcapng												
Ethernet · 14		IPv4 · 4582	IPv6	TCP · 53400		UDP						
Address	Packets ^	Bytes	Total Packets	Percent Filtered	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Country	City	Latitude	Longitude
192.168.10.50	162,305	11 MB	405,940	39.98%	274	23 kB	162,031	11 MB				
172.16.0.1	160,237	11 MB	324,134	49.44%	160,107	11 MB	130	12 kB				
192.168.10.14	5,253	346 kB	244,465	2.15%	5,253	346 kB	0	0 bytes				
192.168.10.15	4,909	323 kB	234,327	2.09%	4,909	323 kB	0	0 bytes				
192.168.10.8	4,703	309 kB	217,186	2.17%	4,703	309 kB	0	0 bytes				
192.168.10.16	4,020	297 kB	219,406	1.83%	4,020	297 kB	0	0 bytes				
192.168.10.5	3,805	251 kB	179,135	2.12%	3,805	251 kB	0	0 bytes				
192.168.10.19	3,482	258 kB	175,828	1.98%	3,482	258 kB	0	0 bytes				
192.168.10.17	3,473	257 kB	198,214	1.75%	3,473	257 kB	0	0 bytes				
192.168.10.9	3,201	211 kB	153,244	2.09%	3,201	211 kB	0	0 bytes				
192.168.10.12	2,384	176 kB	114,286	2.09%	2,384	176 kB	0	0 bytes				
205.174.165.73	2,373	153 kB	4,746	50.00%	0	0 bytes	2,373	153 kB				
192.168.10.25	1,419	110 kB	80,232	1.77%	1,419	110 kB	0	0 bytes				
192.168.10.3	849	61 kB	272,985	0.31%	27	2 kB	822	59 kB				
178.255.83.1	770	53 kB	7,588	10.15%	0	0 bytes	770	53 kB				
72.21.91.29	545	38 kB	15,857	3.44%	0	0 bytes	545	38 kB				
67.72.99.137	479	35 kB	5,746	8.34%	0	0 bytes	479	35 kB				
23.60.139.27	465	32 kB	8,466	5.49%	0	0 bytes	465	32 kB				
192.168.10.51	394	29 kB	8,608	4.58%	394	29 kB	0	0 bytes				
162.213.33.50	394	29 kB	8,057	4.89%	0	0 bytes	394	29 kB				
50.63.243.230	393	27 kB	3,841	10.23%	0	0 bytes	393	27 kB				
199.244.48.55	386	29 kB	41,853	0.92%	0	0 bytes	386	29 kB				
23.61.187.27	373	26 kB	7,884	4.73%	0	0 bytes	373	26 kB				
23.52.155.27	239	17 kB	6,129	3.90%	0	0 bytes	239	17 kB				
69.172.216.111	232	16 kB	4,089	5.67%	0	0 bytes	232	16 kB				
23.50.75.27	218	15 kB	4,667	4.67%	0	0 bytes	218	15 kB				
151.101.21.127	199	15 kB	9,471	2.10%	0	0 bytes	199	15 kB				
199.167.65.25	198	15 kB	9,125	2.17%	0	0 bytes	198	15 kB				
172.217.6.194	177	13 kB	8,020	2.21%	0	0 bytes	177	13 kB				

Zaobserwowałem bardzo wysoki (wyróżniający się) ruch pod względem ilości pakietów dla IP: 192.168.10.50 i 172.16.0.1. Tx Packets dla 172.16.0.1 to aż 160,107 – wysoka liczba, a Rx Packets zaledwie 130. Tx Packets dla 192.168.10.50 to tylko 274, a Rx Packets aż 162,031.

Więc wygląda na zmasowany ruch z 172.16.0.1 do 192.168.10.50.

Wireshark – Statystyki - Conversations wskazuje również na te IP: 172.16.0.1 i 192.168.10.50

Wireshark - Conversations - scenario2.pcapng																
Ethernet - 34		IPv4 - 8071	IPv6	TCP - 195553	UDP											
Address A	Address B	Packets ^	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A		
172.16.0.1	192.168.10.50	160,237	11 MB	159	324,126	49.44%	160,107	11 MB	130	12 kB	477.174081	9964.5143	8,624 bits/s	9 bits/s		
192.168.10.15	205.174.165.73	678	44 kB	59	1,356	50.00%	678	44 kB	0	0 bytes	48.203004	11340.4016	30 bits/s	0 bits/s		
192.168.10.8	205.174.165.73	678	44 kB	62	1,356	50.00%	678	44 kB	0	0 bytes	49.415513	11339.5786	30 bits/s	0 bits/s		
192.168.10.19	67.72.99.137	477	35 kB	1962	5,730	8.32%	477	35 kB	0	0 bytes	3968.224137	43.8367	6,441 bits/s	0 bits/s		
192.168.10.51	162.213.33.50	394	29 kB	24	8,057	4.89%	394	29 kB	0	0 bytes	9.101529	11382.2414	20 bits/s	0 bits/s		
192.168.10.16	199.244.48.55	386	29 kB	7709	41,853	0.92%	386	29 kB	0	0 bytes	10758.635333	139.2274	1,641 bits/s	0 bits/s		
192.168.10.14	205.174.165.73	339	22 kB	64	678	50.00%	339	22 kB	0	0 bytes	55.690235	11315.2282	15 bits/s	0 bits/s		
192.168.10.5	205.174.165.73	339	22 kB	65	678	50.00%	339	22 kB	0	0 bytes	56.656736	11314.5458	15 bits/s	0 bits/s		
192.168.10.9	205.174.165.73	339	22 kB	66	678	50.00%	339	22 kB	0	0 bytes	56.886680	11316.3328	15 bits/s	0 bits/s		
192.168.10.50	192.168.10.25	224	17 kB	72	8,116	2.76%	0	0 bytes	224	17 kB	82.340723	11306.0258	0 bits/s	12 bits/s		
192.168.10.50	192.168.10.12	220	16 kB	51	7,130	3.09%	0	0 bytes	220	16 kB	33.587774	11244.7563	0 bits/s	11 bits/s		
192.168.10.5	192.168.10.50	204	13 kB	69	6,064	3.36%	204	13 kB	0	0 bytes	70.398890	11195.2291	9 bits/s	0 bits/s		
192.168.10.16	192.168.10.50	200	15 kB	32	6,616	3.02%	200	15 kB	0	0 bytes	19.225543	11259.1187	10 bits/s	0 bits/s		
192.168.10.17	151.101.21.127	199	15 kB	7535	9,471	2.10%	199	15 kB	0	0 bytes	10660.732012	732.3835	160 bits/s	0 bits/s		
192.168.10.17	199.167.65.25	198	15 kB	7113	9,125	2.17%	198	15 kB	0	0 bytes	10175.068675	1104.9331	106 bits/s	0 bits/s		
192.168.10.9	192.168.10.50	196	13 kB	67	5,742	3.41%	196	13 kB	0	0 bytes	58.614037	11191.2882	9 bits/s	0 bits/s		
192.168.10.14	192.168.10.50	192	13 kB	166	6,321	3.04%	192	13 kB	0	0 bytes	536.379027	10738.1963	9 bits/s	0 bits/s		
192.168.10.15	192.168.10.50	180	12 kB	54	6,216	2.90%	180	12 kB	0	0 bytes	43.437529	11166.0108	8 bits/s	0 bits/s		
192.168.10.17	192.168.10.50	180	13 kB	98	5,572	3.23%	180	13 kB	0	0 bytes	221.504256	10921.9850	9 bits/s	0 bits/s		
192.168.10.25	192.168.10.3	180	14 kB	114	5,201	3.46%	180	14 kB	0	0 bytes	300.202452	11019.4666	10 bits/s	0 bits/s		
192.168.10.8	192.168.10.50	172	11 kB	79	4,864	3.54%	172	11 kB	0	0 bytes	105.091399	11219.3213	8 bits/s	0 bits/s		
192.168.10.15	178.255.83.1	169	11 kB	263	1,683	10.04%	169	11 kB	0	0 bytes	1547.195983	9739.5046	9 bits/s	0 bits/s		
192.168.10.19	192.168.10.50	156	12 kB	85	5,288	2.95%	156	12 kB	0	0 bytes	160.836443	11012.6709	8 bits/s	0 bits/s		
192.168.10.50	192.168.10.3	144	11 kB	16	19,263	0.75%	144	11 kB	0	0 bytes	4.594583	11384.9170	7 bits/s	0 bits/s		
192.168.10.14	162.208.20.178	144	10 kB	1692	1,648	8.74%	144	10 kB	0	0 bytes	3888.398482	152.7235	497 bits/s	0 bits/s		
192.168.10.25	104.31.91.87	119	9 kB	6720	1,310	9.08%	119	9 kB	0	0 bytes	9640.676813	23.2409	3,195 bits/s	0 bits/s		
192.168.10.17	199.59.88.242	119	9 kB	7114	3,550	3.35%	119	9 kB	0	0 bytes	10175.426447	1220.9159	57 bits/s	0 bits/s		
192.168.10.15	23.60.139.27	111	7 kB	647	2,115	5.25%	111	7 kB	0	0 bytes	2622.734623	7100.4172	8 bits/s	0 bits/s		
192.168.10.16	178.255.83.1	110	8 kB	465	1,121	9.81%	110	8 kB	0	0 bytes	2315.787920	8597.0244	7 bits/s	0 bits/s		
192.168.10.25	203.154.100.144	108	8 kB	6715	2,042	5.29%	108	8 kB	0	0 bytes	9639.276016	25.1597	2,678 bits/s	0 bits/s		
192.168.10.17	185.13.88.201	108	8 kB	7148	4,728	2.28%	108	8 kB	0	0 bytes	10179.672132	1138.5857	56 bits/s	0 bits/s		
192.168.10.14	178.255.83.1	107	7 kB	180	1,001	10.69%	107	7 kB	0	0 bytes	616.734517	10265.4778	5 bits/s	0 bits/s		
192.168.10.9	74.117.200.68	105	7 kB	909	2,161	4.86%	105	7 kB	0	0 bytes	2924.562735	1562.3198	35 bits/s	0 bits/s		

Więc mam parę zgodną z poprzednimi IP, czyli kierunek 172.16.0.1 -> 192.168.10.50

Po zidentyfikowaniu tych adresów ustawiam nowy filtr, aby pokazać ruch podejrzanego IP do jego celu:

"ip.src == ADRES_ATAKUJACEGO (źródła) && ip.dst == ADRES_CELU && tcp.flags.syn == 1 && tcp.flags.ack == 0"

Czyli:

"ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && tcp.flags.syn == 1 && tcp.flags.ack == 0"

scenario2.pcapng																
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help																
ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && tcp.flags.syn == 1 and tcp.flags.ack == 0																
No.	Time	Source	Destination	Protocol	Length	Info										
24519	477.174081	172.16.0.1	192.168.10.50	TCP	74	40956 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=44234246 TSecr=0 WS=128										
78639	2133.743485	172.16.0.1	192.168.10.50	TCP	74	40620 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=44648392 TSecr=0 WS=128										
78845	2140.366683	172.16.0.1	192.168.10.50	TCP	74	40622 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=44659048 TSecr=0 WS=128										
79346	2154.231087	172.16.0.1	192.168.10.50	TCP	74	40626 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=44653515 TSecr=0 WS=128										
79499	2160.732729	172.16.0.1	192.168.10.50	TCP	74	40628 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=44655140 TSecr=0 WS=128										
563725	4921.757650	172.16.0.1	192.168.10.50	TCP	74	40718 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=45345404 TSecr=0 WS=128										
597905	5132.106193	172.16.0.1	192.168.10.50	TCP	60	54987 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
597906	5132.106196	172.16.0.1	192.168.10.50	TCP	60	54987 → 80 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
597910	5132.109257	172.16.0.1	192.168.10.50	TCP	60	54987 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
597911	5132.109260	172.16.0.1	192.168.10.50	TCP	60	54987 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
597942	5133.406781	172.16.0.1	192.168.10.50	TCP	60	54998 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
597974	5134.708560	172.16.0.1	192.168.10.50	TCP	60	54999 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
597998	5136.009946	172.16.0.1	192.168.10.50	TCP	60	55000 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598009	5136.323889	172.16.0.1	192.168.10.50	TCP	60	54987 → 444 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598061	5139.241388	172.16.0.1	192.168.10.50	TCP	60	63214 → 80 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598166	5140.442789	172.16.0.1	192.168.10.50	TCP	60	63214 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598171	5140.445594	172.16.0.1	192.168.10.50	TCP	60	63214 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598172	5140.445640	172.16.0.1	192.168.10.50	TCP	60	63214 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598192	5140.852264	172.16.0.1	192.168.10.50	TCP	60	63214 → 444 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598310	5145.609616	172.16.0.1	192.168.10.50	TCP	60	57636 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598311	5145.609658	172.16.0.1	192.168.10.50	TCP	60	57636 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598329	5146.810680	172.16.0.1	192.168.10.50	TCP	60	57636 → 80 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
598332	5146.813498	172.16.0.1	192.168.10.50	TCP	60	57636 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
599298	5149.125990	172.16.0.1	192.168.10.50	TCP	60	57636 → 444 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
601597	5151.201215	172.16.0.1	192.168.10.50	TCP	60	38040 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
601598	5151.201263	172.16.0.1	192.168.10.50	TCP	60	38040 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
601599	5151.201286	172.16.0.1	192.168.10.50	TCP	60	38040 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
602872	5152.402722	172.16.0.1	192.168.10.50	TCP	60	38040 → 80 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
603220	5152.806100	172.16.0.1	192.168.10.50	TCP	60	38040 → 444 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
604079	5154.104510	172.16.0.1	192.168.10.50	TCP	60	38051 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
605240	5155.406118	172.16.0.1	192.168.10.50	TCP	60	38052 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
605767	5156.737083	172.16.0.1	192.168.10.50	TCP	60	34551 → 80 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
606506	5157.938395	172.16.0.1	192.168.10.50	TCP	60	34551 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
606507	5157.938439	172.16.0.1	192.168.10.50	TCP	60	34551 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
606509	5157.938533	172.16.0.1	192.168.10.50	TCP	60	34551 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
607646	5159.943170	172.16.0.1	192.168.10.50	TCP	60	34551 → 444 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
608069	5162.417325	172.16.0.1	192.168.10.50	TCP	60	49068 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
608070	5162.417396	172.16.0.1	192.168.10.50	TCP	60	49068 → 80 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
608076	5162.420434	172.16.0.1	192.168.10.50	TCP	60	49068 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										
608078	5162.423333	172.16.0.1	192.168.10.50	TCP	60	49068 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460										

Host docelowy: 192.168.10.50 (cel)
Hipoteza: skanowanie licznych portów TCP

Chcę sprawdzić otwarte porty, czyli pary flag SYN, ACK, w tym celu modyfikuje filtr o zmianę z 0 na 1 przy tcp.flags.ack == 0, odpowiedzi SYN, ACK od celu ataku, więc zamieniam miejscami atakującego i cel, czyli teraz reguła brzmi następująco:

“ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && tcp.flags.syn == 1 && tcp.flags.ack == 1”

ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && tcp.flags.syn == 1 and tcp.flags.ack == 1												
No.	Time	Source	Destination	Protocol	Length	Info						
24520	477.174215	192.168.10.50	172.16.0.1	TCP	74	80 → 40556 [SYN, ACK]	Seq=0	Ack=1	Win=28960	Len=0	MSS=1460	SACK_PERM TSval=16690030 TSecr=44234246 WS=128
78631	2133.743616	192.168.10.50	172.16.0.1	TCP	74	80 → 40620 [SYN, ACK]	Seq=0	Ack=1	Win=28960	Len=0	MSS=1460	SACK_PERM TSval=17104173 TSecr=44648392 WS=128
78846	2140.366818	192.168.10.50	172.16.0.1	TCP	74	80 → 40622 [SYN, ACK]	Seq=0	Ack=1	Win=28960	Len=0	MSS=1460	SACK_PERM TSval=17105828 TSecr=44650048 WS=128
79347	2154.231217	192.168.10.50	172.16.0.1	TCP	74	80 → 40626 [SYN, ACK]	Seq=0	Ack=1	Win=28960	Len=0	MSS=1460	SACK_PERM TSval=17109295 TSecr=44653515 WS=128
79500	2160.732851	192.168.10.50	172.16.0.1	TCP	74	80 → 40628 [SYN, ACK]	Seq=0	Ack=1	Win=28960	Len=0	MSS=1460	SACK_PERM TSval=17110920 TSecr=44655140 WS=128
563726	4921.757781	192.168.10.50	172.16.0.1	TCP	74	80 → 40718 [SYN, ACK]	Seq=0	Ack=1	Win=28960	Len=0	MSS=1460	SACK_PERM TSval=17801176 TSecr=45345404 WS=128
597908	5132.106322	192.168.10.50	172.16.0.1	TCP	60	80 → 54987 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
597912	5132.109322	192.168.10.50	172.16.0.1	TCP	60	21 → 54987 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
597913	5132.109371	192.168.10.50	172.16.0.1	TCP	60	22 → 54987 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
598062	5139.241483	192.168.10.50	172.16.0.1	TCP	60	80 → 63214 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
598167	5140.442925	192.168.10.50	172.16.0.1	TCP	60	22 → 63214 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
598173	5140.445663	192.168.10.50	172.16.0.1	TCP	60	21 → 63214 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
598312	5145.609779	192.168.10.50	172.16.0.1	TCP	60	21 → 57636 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
598313	5145.609782	192.168.10.50	172.16.0.1	TCP	60	22 → 57636 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
598330	5146.810806	192.168.10.50	172.16.0.1	TCP	60	80 → 57636 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
601601	5151.201347	192.168.10.50	172.16.0.1	TCP	60	22 → 38040 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
601602	5151.201396	192.168.10.50	172.16.0.1	TCP	60	21 → 38040 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
602873	5152.402849	192.168.10.50	172.16.0.1	TCP	60	80 → 38040 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
605768	5156.737205	192.168.10.50	172.16.0.1	TCP	60	80 → 34551 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
606510	5157.938537	192.168.10.50	172.16.0.1	TCP	60	21 → 34551 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
606511	5157.938589	192.168.10.50	172.16.0.1	TCP	60	22 → 34551 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608071	5162.417458	192.168.10.50	172.16.0.1	TCP	60	22 → 49068 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608072	5162.417483	192.168.10.50	172.16.0.1	TCP	60	80 → 49068 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608079	5162.423382	192.168.10.50	172.16.0.1	TCP	60	21 → 49068 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608561	5168.806531	192.168.10.50	172.16.0.1	TCP	60	22 → 45758 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608565	5168.809495	192.168.10.50	172.16.0.1	TCP	60	80 → 45758 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608567	5168.809553	192.168.10.50	172.16.0.1	TCP	60	21 → 45758 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608820	5173.357064	192.168.10.50	172.16.0.1	TCP	60	80 → 55003 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608821	5173.357094	192.168.10.50	172.16.0.1	TCP	60	21 → 55003 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
608825	5173.360062	192.168.10.50	172.16.0.1	TCP	60	22 → 55003 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609075	5181.413177	192.168.10.50	172.16.0.1	TCP	60	22 → 63860 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609112	5182.614677	192.168.10.50	172.16.0.1	TCP	60	80 → 63860 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609115	5182.617700	192.168.10.50	172.16.0.1	TCP	60	21 → 63860 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609358	5188.001109	192.168.10.50	172.16.0.1	TCP	60	21 → 37710 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609467	5189.202363	192.168.10.50	172.16.0.1	TCP	60	22 → 37710 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609468	5189.202387	192.168.10.50	172.16.0.1	TCP	60	80 → 37710 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609750	5193.736929	192.168.10.50	172.16.0.1	TCP	60	21 → 49467 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609751	5193.736932	192.168.10.50	172.16.0.1	TCP	60	22 → 49467 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
609756	5193.739784	192.168.10.50	172.16.0.1	TCP	60	80 → 49467 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
611847	5199.063543	192.168.10.50	172.16.0.1	TCP	60	21 → 46031 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	

Biorę pod uwagę fragment około 5132 sekundy

172.16.0.1:54987 -> 192.168.10.50:80 | SYN

192.168.10.50:80 -> 172.16.0.1:54987 | SYN, ACK

597908	5132.106322	192.168.10.50	172.16.0.1	TCP	60	80 → 54987 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
597912	5132.109322	192.168.10.50	172.16.0.1	TCP	60	21 → 54987 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	
597913	5132.109371	192.168.10.50	172.16.0.1	TCP	60	22 → 54987 [SYN, ACK]	Seq=0	Ack=1	Win=29200	Len=0	MSS=1460	

Jest odpowiedź z portu 80, 21, 22

5132.106190 — 172.16.0.1:54987 -> 192.168.10.50:80 | SYN, próba sprawdzenia portu 80

5132.106322 — 192.168.10.50:80 -> 172.16.0.1:54987 | SYN, ACK; port 80 odpowiada jako otwarty

5132.109257 — 172.16.0.1:54987 -> 192.168.10.50:21 | SYN, próba sprawdzenia portu 21

5132.109322 — 192.168.10.50:21 -> 172.16.0.1:54987 | SYN, ACK; port 21 odpowiada jako otwarty

5132.109260 — 172.16.0.1:54987 -> 192.168.10.50:22 | SYN, próba sprawdzenia portu 22

5132.109371 — 192.168.10.50:22 -> 172.16.0.1:54987 |SYN, ACK; port 22 odpowiada jako otwarty.

TCP/21 - FTP

TCP/22 - SSH

TCP/80 - HTTP

Chcę zobaczyć jeszcze, które porty odrzucają prośby SYN, czyli znowu tutaj źródłem ma być cel, czyli IP 192.168.10.50.

```
ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && tcp.flags.reset == 1
```

[illegible]

Podglądam detale No. 597907, również z okolic czasu 5132 sekund:

```
Transmission Control Protocol, Src Port: 443, Dst Port: 54987, Seq: 1, Ack: 1, Len: 0
Source Port: 443
Destination Port: 54987
[Stream index: 11165]
[Stream Packet Number: 2]
[Conversation completeness: Incomplete (37)]
[TCP Segment Len: 0]
Sequence Number: 1 (relative sequence number)
Sequence Number (raw): 0
[Next Sequence Number: 1 (relative sequence number)]
Acknowledgment Number: 1 (relative ack number)
Acknowledgment number (raw): 2540338813
0101 .... = Header Length: 20 bytes (5)
Flags: 0x014 (RST, ACK)
000. .... = Reserved: Not set
...0 .... = Accurate ECN: Not set
.... 0... = Congestion Window Reduced: Not set
.... .0.. = ECN-Echo: Not set
.... ..0. = Urgent: Not set
.... ...1 = Acknowledgment: Set
.... .... 0... = Push: Not set
.... .... .1.. = Reset: Set
[Expert Info (Warning/Sequence): Connection reset (RST)]
[Connection reset (RST)]
[Severity level: Warning]
[Group: Sequence]
.... .... ..0. = Syn: Not set
.... .... ...0 = Fin: Not set
[TCP Flags: .....A.R..]
Window: 0
[Calculated window size: 0]
[Window size scaling factor: -2 (no window scaling used)]
Checksum: 0x4a76 [unverified]
[Checksum Status: Unverified]
Urgent Pointer: 0
[Timestamps]
[Time since first frame in this TCP stream: 102.000 microseconds]
[Time since previous frame in this TCP stream: 102.000 microseconds]
[SEQ/ACK analysis]
[This is an ACK to the segment in frame: 597905]
[The RTT to ACK the segment was: 102.000 microseconds]
[RTT: 102.000 microseconds]
0000 00 c1 b1 14 eb 31 00 19 b9 0a 69 f1 08 00 45 00 .....1.. ..i...E..

No.: 597907 · Time: 5132.106295 · Source: 192.168.10.50 · Destination: 172.16.0.1 · Protocol: TCP · Length: 60 · Info: 443 → 54987 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
```

W sytuacji portu 443, widzę flagi RST, ACK - ten port jest zamknięty na 192.168.10.50

Dodatkowo filtr dla flagi RST na poprzednim screenie pokazuje aż 158798 takich resetów. To kolejny dowód na sądownie/szukanie otwartych portów.

RAPORT Z BADANEGO INCYDENTU:

Zakres materiału

- Nazwa i SHA-256 pliku:

scenari2.pcapng

SHA-256: 44b7c43c4df7e047ee2001242eaf06117f23ec8414c64dea5784ffba1a4f5c23

- Źródło i punkt przechwycenia:

Źródłem materiału jest zapis ruchu sieciowego z pliku scenari2.pcapng, analizowany w programie

Wireshark. Punkt przechwycenia ruchu nie został określony. W analizowanym zdarzeniu zidentyfikowano komunikację pomiędzy 172.16.0.1 a 192.168.10.50.

- **Przedział czasu i strefa:**

Analizowany fragment zdarzenia występuje około 5132.106–5132.109 s. Na podstawie tej analizy nie ustalono czasu rozpoczęcia i zakończenia zdarzenia ani strefy czasowej.

- **Znane ograniczenia:**

Analiza została wykonana wyłącznie na podstawie dostarczonego pliku .pcap. Zaznaczam brak łączy z logami systemowymi, firewall-em, IDS/IPS, dlatego na podstawie samego .pcap nie można jednoznacznie określić, czy skanowanie miało autoryzację.

Podsumowanie

W zapisanym ruchu zidentyfikowano dużą liczbę pakietów protokołu TCP dla flagi SYN wysyłanych z hosta 172.16.0.1 do różnych portów hosta 192.168.10.50. Statystyki Wiresharka wskazują na silnie asymetryczny ruch pomiędzy tymi hostami, a odpowiedzi celu flagi: SYN, ACK oraz RST, ACK potwierdzają sondowanie stanu poszczególnych portów (czy otwarte i gotowe do komunikacji, czy są zamknięte). Zaobserwowany wzorzec wskazuje z wysokim prawdopodobieństwem na skanowanie portów za pomocą protokołu TCP.

Chronologia

Time 5132.106190 | 172.16.0.1:54987 -> 192.168.10.50:80 - wysłano TCP SYN, próba sprawdzenia portu 80

Time 5132.106322 | 192.168.10.50:80 -> 172.16.0.1:54987 - odpowiedź SYN, ACK; port 80 odpowiada jako otwarty

Time 5132.106193 | 172.16.0.1:54987 -> 192.168.10.50:443 - wysłano TCP SYN do portu 443

Time 5132.106295 | 192.168.10.50:443 -> 172.16.0.1:54987 - odpowiedź RST, ACK; port 443 odpowiada jako zamknięty

Time 5132.109257 | 172.16.0.1:54987 -> 192.168.10.50:21 - wysłano TCP SYN do portu 21

Time 5132.109322 | 192.168.10.50:21 -> 172.16.0.1:54987 - odpowiedź SYN, ACK; port 21 odpowiada jako otwarty

Time 5132.109260 | 172.16.0.1:54987 -> 192.168.10.50:22 - wysłano TCP SYN do portu 22

Time 5132.109371 | 192.168.10.50:22 -> 172.16.0.1:54987 - odpowiedź SYN, ACK; port 22 odpowiada jako otwarty

Dowody

Numer ramki lub strumienia:

597905 / 597907 - próba połączenia z TCP/443 i odpowiedź RST, ACK

597906 / 597908 - próba połączenia z TCP/80 i odpowiedź SYN, ACK

597910 / 597912 - próba połączenia z TCP/21 i odpowiedź SYN, ACK

597911 / 597913 - próba połączenia z TCP/22 i odpowiedź SYN, ACK

Zastosowane filtry:

tcp.flags.syn == 1 && tcp.flags.ack == 0

ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && tcp.flags.syn == 1 && tcp.flags.ack == 0

ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && tcp.flags.syn == 1 && tcp.flags.ack == 1

ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && tcp.flags.reset == 1

Zaobserwowane pola i statystyki:

Analizowano adresy IP źródłowe i docelowe, skanowane porty TCP oraz flagi SYN, ACK i RST. Host 172.16.0.1 wygenerował 160 107 pakietów Tx przy jedynie 130 pakietach Rx, natomiast host 192.168.10.50 odebrał 162 031 pakietów przy 274 pakietach Tx. Statystyki "Conversations" również wskazały dominujący kierunek komunikacji na linii 172.16.0.1 → 192.168.10.50. Zaobserwowano odpowiedzi z flagami SYN, ACK między innymi dla portów 21, 22 i 80 oraz flagi RST, ACK dla portu 443.

Ocena

Hipoteza:

Host z adresu IPv4 172.16.0.1 wykonywał skanowanie portów TCP hosta do adresu IPv4 192.168.10.50 w celu sprawdzenia, które usługi są dostępne.

Alternatywne wyjaśnienie:

Zaobserwowany ruch mógł pochodzić od Administratorów systemów/sieci, systemu monitoringu lub autoryzowanego testu zabezpieczeń sieci.

Poziom pewności:

Wysoki

Rekomendowane działania

Korelacja z logami lub EDR:

Zestawić czas wystąpienia skanowania portów z logami firewall-a, IDS/IPS, systemu operacyjnego oraz EDR w celu potwierdzenia źródła ruchu i ustalenia czy działanie było wykonywane przez autoryzowane osoby/systemy.

Identyfikacja właściciela i procesu:

Ustalić właściciela hosta z adresu: 172.16.0.1 oraz proces, osoby lub aplikację odpowiedzialną za generowanie dużej liczby połączeń TCP do 192.168.10.50.

Ewentualna izolacja zgodnie z procedurą IR:

Jeżeli skanowanie portów nie było działaniem autoryzowanym, rozważyć ograniczenie komunikacji lub izolowanie hosta z IPv4 172.16.0.1 zgodnie z obowiązującymi procedurami i zasadami. Cały czas obserwować i analizować 172.16.0.1 i domenę, z której pochodzi.

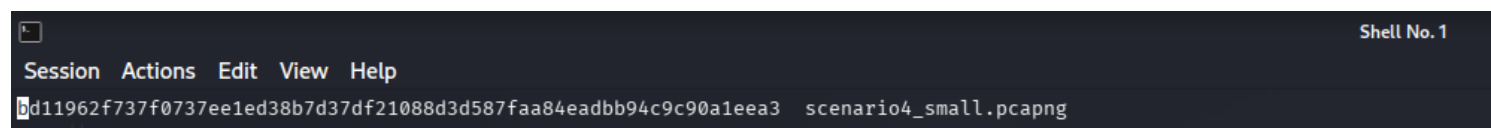
[KONIEC RAPORTU]

Zadanie nr 4

nazwa i SHA-256 pliku:

scenario4_small.pcapng

Bd11962f737f0737ee1ed38b7d37df21088d3d587faa84eadbb94c9c90a1eea3



Na początku chce zawęzić wyniki przez użycie filtru:

“http.request”

scenario4_small.pcapng						
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help						
http.request						
No.	Time	Source	Destination	Protocol	Length	Info
12	0.923186	172.16.0.1	192.168.10.50	HTTP	449	GET /dv/vulnerabilities/xss_r/ HTTP/1.1
15	0.928510	172.16.0.1	192.168.10.50	HTTP	422	GET /dv/login.php HTTP/1.1
24	1.171969	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
27	1.176916	172.16.0.1	192.168.10.50	HTTP	467	GET /dv/login.php HTTP/1.1
55	3.189697	172.16.0.1	192.168.10.50	HTTP	449	GET /dv/vulnerabilities/xss_r/ HTTP/1.1
58	3.186839	172.16.0.1	192.168.10.50	HTTP	422	GET /dv/login.php HTTP/1.1
74	3.433348	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
77	3.437891	172.16.0.1	192.168.10.50	HTTP	467	GET /dv/login.php HTTP/1.1
137	5.444463	172.16.0.1	192.168.10.50	HTTP	449	GET /dv/vulnerabilities/xss_r/ HTTP/1.1
149	5.451327	172.16.0.1	192.168.10.50	HTTP	422	GET /dv/login.php HTTP/1.1
148	5.726602	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
151	5.732370	172.16.0.1	192.168.10.50	HTTP	467	GET /dv/login.php HTTP/1.1
214	7.737432	172.16.0.1	192.168.10.50	HTTP	449	GET /dv/vulnerabilities/xss_r/ HTTP/1.1
217	7.743226	172.16.0.1	192.168.10.50	HTTP	422	GET /dv/login.php HTTP/1.1
225	7.984129	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
228	7.989805	172.16.0.1	192.168.10.50	HTTP	467	GET /dv/login.php HTTP/1.1
251	9.995288	172.16.0.1	192.168.10.50	HTTP	449	GET /dv/vulnerabilities/xss_r/ HTTP/1.1
254	10.001272	172.16.0.1	192.168.10.50	HTTP	422	GET /dv/login.php HTTP/1.1
260	10.263951	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
263	10.268436	172.16.0.1	192.168.10.50	HTTP	467	GET /dv/login.php HTTP/1.1
503	24.711275	192.168.10.51	72.21.91.29	OCSP	503	Request
507	24.786676	192.168.10.51	72.21.91.29	OCSP	503	Request
515	24.959756	192.168.10.51	63.121.30.147	HTTP	377	GET /geo/siteselection HTTP/1.1
522	25.056501	192.168.10.51	68.142.108.145	HTTP	356	GET / HTTP/1.1
530	25.343437	192.168.10.51	72.21.91.29	OCSP	503	Request
539	25.345529	192.168.10.51	178.255.83.1	OCSP	504	Request
542	25.361595	192.168.10.51	23.60.139.27	OCSP	498	Request
555	25.368200	192.168.10.51	72.21.91.29	OCSP	503	Request
556	25.368280	192.168.10.51	72.21.91.29	OCSP	503	Request
575	25.896191	192.168.10.51	172.217.6.206	OCSP	501	[TCP Previous segment not captured] Request
580	26.020232	192.168.10.51	72.21.91.29	OCSP	503	Request
587	26.360157	192.168.10.51	172.217.6.206	OCSP	501	Request
598	26.431822	192.168.10.51	23.50.75.27	OCSP	498	Request
612	26.496904	192.168.10.51	72.21.91.29	OCSP	503	Request
626	26.768921	192.168.10.51	23.50.75.27	OCSP	498	Request
634	26.857343	172.16.0.1	192.168.10.50	HTTP	375	GET /dv/vulnerabilities/xss_r/ HTTP/1.1
638	26.874115	172.16.0.1	192.168.10.50	HTTP	408	GET /dv/login.php HTTP/1.1
642	26.907711	172.16.0.1	192.168.10.50	HTTP	431	GET /dv/dwaa/css/login.css HTTP/1.1
644	26.909042	172.16.0.1	192.168.10.50	HTTP	454	GET /dv/dwaa/images/login_logo.png HTTP/1.1
657	26.975174	172.16.0.1	192.168.10.50	HTTP	377	GET /favicon.ico HTTP/1.1
Frame 12: Packet 449 bytes on wire (3502 bits) 449 bytes captured (3502 bits) on interface unknown						
Request: Boolean						
Packets: 450985 - Displayed: 9751 (2.2%)						

Myślę, że to dobry trop, zawęził mi obszar monitoringu do 2,2% zarejestrowanych wpisów z pliku.

Próbując zawęzić obszar poszukiwań jeszcze dalej, to zgodnie ze źródłem: <https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses> - chce użyć filtra, który pokaże mi te zapytania:

“http.request.method == "POST"”

http.request.method == "POST"						
No.	Time	Source	Destination	Protocol	Length	Info
24	1.171969	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
74	3.433348	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
148	5.726602	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
225	7.984129	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
260	10.263951	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
503	24.711275	192.168.10.51	72.21.91.29	OCSP	503	Request
507	24.786676	192.168.10.51	72.21.91.29	OCSP	503	Request
530	25.343437	192.168.10.51	72.21.91.29	OCSP	503	Request
539	25.345529	192.168.10.51	178.255.83.1	OCSP	504	Request
542	25.361595	192.168.10.51	23.60.139.27	OCSP	498	Request
555	25.368200	192.168.10.51	72.21.91.29	OCSP	503	Request
556	25.368280	192.168.10.51	72.21.91.29	OCSP	503	Request
575	25.896191	192.168.10.51	172.217.6.206	OCSP	501	[TCP Previous segment not captured] Request
580	26.020232	192.168.10.51	72.21.91.29	OCSP	503	Request
587	26.360157	192.168.10.51	172.217.6.206	OCSP	501	Request
598	26.431822	192.168.10.51	23.50.75.27	OCSP	498	Request
612	26.496904	192.168.10.51	72.21.91.29	OCSP	503	Request
626	26.768921	192.168.10.51	23.50.75.27	OCSP	498	Request
678	28.061276	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
689	28.099884	192.168.10.51	72.21.91.29	OCSP	503	Request
700	28.345572	192.168.10.51	178.255.83.1	OCSP	504	Request
720	28.537018	192.168.10.51	178.255.83.1	OCSP	505	Request
721	28.537073	192.168.10.51	178.255.83.1	OCSP	505	Request
740	28.725963	192.168.10.51	72.21.91.29	OCSP	503	Request
743	28.759995	192.168.10.51	72.21.91.29	OCSP	503	Request
752	29.336986	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
764	29.399214	192.168.10.51	50.63.243.230	OCSP	494	Request
783	29.765190	192.168.10.51	52.84.40.197	OCSP	512	Request
792	30.262294	192.168.10.51	23.50.75.27	OCSP	498	Request
805	30.595299	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
844	31.855671	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
886	33.113502	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
929	34.412739	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
970	35.683974	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
1016	36.949538	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
1062	38.208807	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
1125	39.465539	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
1149	40.741615	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
1178	42.002915	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
1201	43.256932	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
Frame 24: Packet 668 bytes on wire (5344 bits) 668 bytes captured (5344 bits) on interface unknown						
scenario4_small.pcapng						
Packets: 450985 - Displayed: 2711 (0.6%)						

Widzę już wielokrotnie:

“172.16.0.1 → 192.168.10.50 POST /dv/login.php HTTP/1.1 application/x-www-form-urlencoded”

- ten sam IPv4 wysyła wiele żądań POST do tego samego endpointu.

Tak jak i przy zadaniu numer 2, używam w Wireshark – Statistics -> Endpoints. Filtruje wynik po ilości packetów dla IPv4. Zyskuje obraz, który pokazuje mi, że adresy 172.16.0.1 i 192.168.10.50 mają po największej ilości pakietów: 1344 każdy. Tx Packets dla 172.16.0.1 to 1344, Rx Packets 0. Tx Packets dla 192.168.10.50 to 0, Rx Packets 1344.

Wireshark - Endpoints - scenario4_small.pcapng												
Ethernet - 13		IPv4 - 76	IPv6	TCP - 936	UDP							
Address	Packets ^	Bytes	Total Packets	Percent Filtered	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Country	City	Latitude	Longitude
172.16.0.1	1,344	898 kB	22,237	6.04%	1,344	898 kB	0	0 bytes				
192.168.10.50	1,344	898 kB	22,237	6.04%	0	0 bytes	1,344	898 kB				
192.168.10.15	398	222 kB	362,159	0.11%	398	222 kB	0	0 bytes				
72.21.91.29	274	135 kB	2,993	9.15%	0	0 bytes	274	135 kB				
23.50.75.27	235	115 kB	3,286	7.15%	0	0 bytes	235	115 kB				
178.255.83.1	192	95 kB	2,265	8.48%	0	0 bytes	192	95 kB				
192.168.10.5	159	83 kB	4,157	3.82%	159	83 kB	0	0 bytes				
192.168.10.19	144	87 kB	19,970	0.72%	144	87 kB	0	0 bytes				
192.168.10.17	141	71 kB	23,680	0.60%	141	71 kB	0	0 bytes				
23.60.139.27	139	68 kB	2,042	6.81%	0	0 bytes	139	68 kB				
192.168.10.9	131	93 kB	8,170	1.60%	131	93 kB	0	0 bytes				
192.168.10.8	119	58 kB	1,928	6.17%	119	58 kB	0	0 bytes				
192.168.10.12	111	56 kB	1,567	7.08%	111	56 kB	0	0 bytes				
50.63.243.230	95	46 kB	1,051	9.04%	0	0 bytes	95	46 kB				
192.168.10.16	82	41 kB	1,489	5.51%	82	41 kB	0	0 bytes				
172.217.9.238	66	32 kB	859	7.68%	0	0 bytes	66	32 kB				
172.217.12.174	63	31 kB	923	6.83%	0	0 bytes	63	31 kB				
72.167.239.239	61	30 kB	722	8.45%	0	0 bytes	61	30 kB				
192.168.10.14	49	24 kB	2,919	1.68%	49	24 kB	0	0 bytes				
172.217.7.14	40	20 kB	556	7.19%	0	0 bytes	40	20 kB				
192.168.10.51	31	16 kB	2,641	1.17%	31	16 kB	0	0 bytes				
54.192.36.201	21	11 kB	223	9.42%	0	0 bytes	21	11 kB				
172.217.6.206	16	8 kB	310	5.16%	0	0 bytes	16	8 kB				
68.67.180.44	13	23 kB	145	8.97%	0	0 bytes	13	23 kB				
23.208.165.24	11	5 kB	285	3.86%	0	0 bytes	11	5 kB				
104.16.28.216	8	4 kB	107	7.48%	0	0 bytes	8	4 kB				
52.207.54.198	8	8 kB	196	4.08%	0	0 bytes	8	8 kB				
52.203.66.59	8	16 kB	207	3.86%	0	0 bytes	8	16 kB				
52.84.40.136	7	3 kB	120	5.83%	0	0 bytes	7	3 kB				
23.15.4.8	7	3 kB	220	3.18%	0	0 bytes	7	3 kB				
52.84.40.204	6	3 kB	187	3.21%	0	0 bytes	6	3 kB				
68.67.178.170	5	9 kB	92	5.43%	0	0 bytes	5	9 kB				
104.16.27.216	5	3 kB	55	9.09%	0	0 bytes	5	3 kB				

Tak jak i przy zadaniu numer 2, używam w Wireshark – Statistics -> Conversations. Filtruje wynik po ilości packetów dla IPv4. Zyskuje obraz, który pokazuje mi, że adresy 172.16.0.1 i 192.168.10.50 mają po największej ilości pakietów. Komunikacja A -> B (172.16.0.1 -> 192.168.10.50) to 1344, natomiast komunikacja B -> to 0.

Wireshark - Conversations - scenario4_small.pcapng															
Ethernet - 12		IPv4 - 157	IPv6	TCP - 872	UDP										
Address A	Address B	Packets ^	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A	
172.16.0.1	192.168.10.50	1,344	898 kB	4	22,237	6.04%	1,344	898 kB	0	0 bytes	0.923186	1728.9304	4,154 bits/s	0 bits/s	
192.168.10.15	72.21.91.29	100	49 kB	36	786	12.72%	100	49 kB	0	0 bytes	8.302317	1711.7737	229 bits/s	0 bits/s	
192.168.10.15	23.60.139.27	59	28 kB	371	969	6.09%	59	28 kB	0	0 bytes	792.295759	666.7086	341 bits/s	0 bits/s	
192.168.10.15	178.255.83.1	51	25 kB	369	598	8.53%	51	25 kB	0	0 bytes	788.532241	871.1945	229 bits/s	0 bits/s	
192.168.10.15	50.63.243.230	44	21 kB	503	467	9.42%	44	21 kB	0	0 bytes	1072.194875	21.2391	7,976 bits/s	0 bits/s	
192.168.10.15	23.50.75.27	42	20 kB	83	418	10.05%	42	20 kB	0	0 bytes	167.706353	1559.7337	104 bits/s	0 bits/s	
192.168.10.12	23.50.75.27	41	20 kB	74	455	9.01%	41	20 kB	0	0 bytes	146.696698	1034.6617	158 bits/s	0 bits/s	
192.168.10.5	23.50.75.27	38	18 kB	35	580	6.55%	38	18 kB	0	0 bytes	8.065996	1631.2809	89 bits/s	0 bits/s	
192.168.10.19	23.50.75.27	38	19 kB	465	451	8.43%	38	19 kB	0	0 bytes	973.175880	356.0120	424 bits/s	0 bits/s	
192.168.10.8	72.21.91.29	37	18 kB	395	494	7.49%	37	18 kB	0	0 bytes	870.781292	626.3168	231 bits/s	0 bits/s	
192.168.10.5	72.21.91.29	34	17 kB	321	324	10.49%	34	17 kB	0	0 bytes	593.335982	1048.0417	126 bits/s	0 bits/s	
192.168.10.17	72.21.91.29	32	16 kB	27	397	8.06%	32	16 kB	0	0 bytes	6.190252	1675.4140	77 bits/s	0 bits/s	
192.168.10.9	23.60.139.27	31	15 kB	618	269	11.52%	31	15 kB	0	0 bytes	1448.332068	278.6917	430 bits/s	0 bits/s	
192.168.10.19	178.255.83.1	29	15 kB	282	301	9.63%	29	15 kB	0	0 bytes	511.050656	920.2823	127 bits/s	0 bits/s	
192.168.10.17	23.60.139.27	28	14 kB	184	367	7.63%	28	14 kB	0	0 bytes	459.269898	994.4181	112 bits/s	0 bits/s	
192.168.10.8	172.217.9.238	23	11 kB	399	266	8.65%	23	11 kB	0	0 bytes	873.586609	856.0051	104 bits/s	0 bits/s	
192.168.10.5	178.255.83.1	22	11 kB	312	251	8.76%	22	11 kB	0	0 bytes	592.770998	933.1430	92 bits/s	0 bits/s	
192.168.10.8	178.255.83.1	22	11 kB	351	249	8.84%	22	11 kB	0	0 bytes	667.910975	1011.3430	85 bits/s	0 bits/s	
192.168.10.9	72.21.91.29	21	10 kB	619	231	9.09%	21	10 kB	0	0 bytes	1449.401480	277.2958	296 bits/s	0 bits/s	
192.168.10.12	178.255.83.1	21	11 kB	78	242	8.68%	21	11 kB	0	0 bytes	148.068349	1026.6863	82 bits/s	0 bits/s	
192.168.10.15	172.217.9.238	21	10 kB	368	233	9.01%	21	10 kB	0	0 bytes	788.410764	279.0687	293 bits/s	0 bits/s	
192.168.10.8	23.50.75.27	18	9 kB	348	403	4.47%	18	9 kB	0	0 bytes	666.433636	526.8816	132 bits/s	0 bits/s	
192.168.10.15	72.167.239.239	18	9 kB	81	224	8.04%	18	9 kB	0	0 bytes	158.030137	1072.9822	64 bits/s	0 bits/s	
192.168.10.15	54.192.36.201	17	8 kB	505	126	13.49%	17	8 kB	0	0 bytes	1073.345103	128.3978	528 bits/s	0 bits/s	
192.168.10.16	23.50.75.27	17	8 kB	296	266	6.39%	17	8 kB	0	0 bytes	579.802028	119.8042	565 bits/s	0 bits/s	
192.168.10.17	23.50.75.27	17	9 kB	17	304	5.59%	17	9 kB	0	0 bytes	3.726261	1677.8783	40 bits/s	0 bits/s	
192.168.10.5	50.63.243.230	16	8 kB	500	177	9.04%	16	8 kB	0	0 bytes	1056.792906	475.4059	129 bits/s	0 bits/s	
192.168.10.16	172.217.12.174	16	8 kB	614	253	6.32%	16	8 kB	0	0 bytes	1390.167946	117.3988	546 bits/s	0 bits/s	
192.168.10.16	178.255.83.1	16	8 kB	136	220	7.27%	16	8 kB	0	0 bytes	347.085712	1049.7928	61 bits/s	0 bits/s	
192.168.10.19	72.21.91.29	16	8 kB	442	170	9.41%	16	8 kB	0	0 bytes	971.198742	483.0618	133 bits/s	0 bits/s	
192.168.10.17	178.255.83.1	15	8 kB	219	187	8.02%	15	8 kB	0	0 bytes	460.399968	1107.3268	54 bits/s	0 bits/s	
192.168.10.9	50.63.243.230	14	7 kB	289	153	9.15%	14	7 kB	0	0 bytes	511.386893	1215.0936	44 bits/s	0 bits/s	
192.168.10.9	172.217.12.174	14	7 kB	620	171	8.19%	14	7 kB	0	0 bytes	1449.418927	120.5659	452 bits/s	0 bits/s	

× Close🔗 Help

Z dużą dozą prawdopodobieństwa, znalazłem odpowiednią parę adresów IPv4.

Teraz na podstawie informacji pokazanych za pomocą filtra: " http.request.method == "POST", w dużej mierze analogicznie do zadania numer 2, uszczelniam filtr poszukiwań na:

"ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && http.request.method == "POST" && http.request.uri == "/dv/login.php"

ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && http.request.method == "POST" && http.request.uri == "/dv/login.php"							
No.	Time	Source	Destination	Protocol	Length	Info	
24	1.171969	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
74	3.433348	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
148	5.726602	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
225	7.984129	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
260	10.263951	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
678	28.061276	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
752	29.336986	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
805	30.595299	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
844	31.855671	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
886	33.113502	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
929	34.412739	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
970	35.683974	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1016	36.949538	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1062	38.208807	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1125	39.465539	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1149	40.741615	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1178	42.002915	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1201	43.256932	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1233	44.575612	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1266	45.843854	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1315	47.103908	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1351	48.371421	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1389	49.631016	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1401	51.009133	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1424	52.268991	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1450	53.527699	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1478	54.786092	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1508	56.042006	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1562	57.321432	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1595	58.580917	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1621	59.844899	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1642	61.105302	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1665	62.368563	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1694	63.647734	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1723	64.906659	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1750	66.169146	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1806	67.439751	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1834	68.699441	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1861	69.995122	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	
1911	71.259366	172.16.0.1	192.168.10.50	HTTP	668	POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)	

Ethernet II, Src: Cisco_14:eb:31 (00:c1:b1:14:eb:31), Dst: Dell_0a:69:f1 (00:19:b9:0a:69:f1) 0000 00 19 b9 0a 69 f1 00 c1 b1 14 eb 31 08 00 45 00 ... 1

scenario4_small.pcapng Packets: 450985 · Displayed: 1344 (0.3%)

Wynik filtrowania zwraca mi 1344 pakiety. To oznacza, że w komunikacji z 172.16.0.1 do 192.168.10.50 wystąpiło 1344 żądań POST skierowanych dokładnie do /dv/login.php.

Podejrzę ramkę numer 24, aby dowiedzieć się więcej:

Wireshark · Packet 24 · scenario4_small.pcapng

▶ Frame 24: Packet, 668 bytes on wire (5344 bits), 668 bytes captured (5344 bits) on interface unknown, id 0

▶ Ethernet II, Src: Cisco_14:eb:31 (00:c1:b1:14:eb:31), Dst: Dell_0a:69:f1 (00:19:b9:0a:69:f1)

▶ Internet Protocol Version 4, Src: 172.16.0.1, Dst: 192.168.10.50

▶ Transmission Control Protocol, Src Port: 44634, Dst Port: 80, Seq: 740, Ack: 1420, Len: 602

▼ Hypertext Transfer Protocol

▶ POST /dv/login.php HTTP/1.1\r\nHost: 205.174.165.68\r\nUser-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0\r\nAccept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8\r\nAccept-Language: en-US,en;q=0.5\r\nAccept-Encoding: gzip, deflate\r\nReferer: http://205.174.165.68/dv/login.php\r\nCookie: security=low; PHPSESSID=arvio4k1tk140p62tqvge4enp5\r\nConnection: keep-alive\r\nContent-Type: application/x-www-form-urlencoded\r\nContent-Length: 130\r\n\r\n[Response in frame: 25]
[Full request URI: http://205.174.165.68/dv/login.php]
File Data: 130 bytes

▼ HTML Form URL Encoded: application/x-www-form-urlencoded

▼ Form item: "username" = "admin"

Key: username
Value: admin

▼ Form item: "password" = "FPXYEPA7B37P8B7EXTSRCG38CLGWE1TZY37PHKZLEK0FGQRTE"

Key: password
Value: FPXYEPA7B37P8B7EXTSRCG38CLGWE1TZY37PHKZLEK0FGQRTE

▼ Form item: "Login" = "Login"

Key: Login
Value: Login

▼ Form item: "user_token" = "68c5e13bfb76d0a4cb431467b7bf000f"

Key: user_token
Value: 68c5e13bfb76d0a4cb431467b7bf000f

A w tej ramce numer 24 są istotne fragmenty jak “username”, “password”, “Login”, “user_token”:

```
▼ Hypertext Transfer Protocol
  ▶ POST /dv/login.php HTTP/1.1\r\n
    Host: 205.174.165.68\r\n
    User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0\r\n
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8\r\n
    Accept-Language: en-US,en;q=0.5\r\n
    Accept-Encoding: gzip, deflate\r\n
    Referer: http://205.174.165.68/dv/login.php\r\n
  ▼ Cookie: security=low; PHPSESSID=arvio4k1tk140p62tqvge4enp5\r\n
    Cookie pair: security=low
    Cookie pair: PHPSESSID=arvio4k1tk140p62tqvge4enp5
    Connection: keep-alive\r\n
    Content-Type: application/x-www-form-urlencoded\r\n
  ▼ Content-Length: 130\r\n
    [Content length: 130]
    \r\n
    [Response in frame: 25]
    [Full request URI: http://205.174.165.68/dv/login.php]
    File Data: 130 bytes
▼ HTML Form URL Encoded: application/x-www-form-urlencoded
  ▼ Form item: "username" = "admin"
    Key: username
    Value: admin
  ▼ Form item: "password" = "FPXYEPRA7B37P8B7EXTSRCG38CLGWE1TZY37PHKZLEK0FGQRTE"
    Key: password
    Value: FPXYEPRA7B37P8B7EXTSRCG38CLGWE1TZY37PHKZLEK0FGQRTE
  ▼ Form item: "Login" = "Login"
    Key: Login
    Value: Login
  ▼ Form item: "user_token" = "68c5e13bfb76d0a4cb431467b7bf000f"
    Key: user_token
    Value: 68c5e13bfb76d0a4cb431467b7bf000f
```

Przesyłane jest, próby logowania login i hasło i to wielokrotnie. Login jest cały czas: admin, hasło zmienia się w kolejnych zapytaniach.

```

▶ Frame 74: Packet, 668 bytes on wire (5344 bits), 668 bytes captured (5344 bits) on interface unknown, id 0
▶ Ethernet II, Src: Cisco_14:eb:31 (00:c1:b1:14:eb:31), Dst: Dell_0a:69:f1 (00:19:b9:0a:69:f1)
▶ Internet Protocol Version 4, Src: 172.16.0.1, Dst: 192.168.10.50
▶ Transmission Control Protocol, Src Port: 44634, Dst Port: 80, Seq: 2482, Ack: 4268, Len: 602
▼ Hypertext Transfer Protocol
  ▶ POST /dv/login.php HTTP/1.1\r\n
    Request Method: POST
    Request URI: /dv/login.php
    Request Version: HTTP/1.1
    Host: 205.174.165.68\r\n
    User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0\r\n
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8\r\n
    Accept-Language: en-US,en;q=0.5\r\n
    Accept-Encoding: gzip, deflate\r\n
    Referer: http://205.174.165.68/dv/login.php\r\n
  ▼ Cookie: security=low; PHPSESSID=arvio4k1tk140p62tqvge4enp5\r\n
    Cookie pair: security=low
    Cookie pair: PHPSESSID=arvio4k1tk140p62tqvge4enp5
    Connection: keep-alive\r\n
    Content-Type: application/x-www-form-urlencoded\r\n
  ▼ Content-Length: 130\r\n
    [Content length: 130]
    \r\n
    [Response in frame: 75]
    [Full request URI: http://205.174.165.68/dv/login.php]
    File Data: 130 bytes
▼ HTML Form URL Encoded: application/x-www-form-urlencoded
  ▼ Form item: "username" = "admin"
    Key: username
    Value: admin
  ▼ Form item: "password" = "N0FRWFI6Z13UURW52UF07W6ZCTVT603Q7TNTYLJIZQ3N9AD29T"
    Key: password
    Value: N0FRWFI6Z13UURW52UF07W6ZCTVT603Q7TNTYLJIZQ3N9AD29T
  ▼ Form item: "Login" = "Login"
    Key: Login
    Value: Login
  ▼ Form item: "user_token" = "6c1456a7bfab56a9e2699e75578be647"
    Key: user_token
    Value: 6c1456a7bfab56a9e2699e75578be647

```

```

0000  00 19 b9 0a 69 f1 00 c1  b1 14 eb 31 08 00 45 00  ....i... ..1..E.

```

No.: 74 · Time: 3.433348 · Source: 172.16.0.1 · Destination: 192.168.10.50 · Protocol: HTTP · Length: 668 · Info: POST /dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)

```

▶ Frame 148: Packet, 668 bytes on wire (5344 bits), 668 bytes captured (5344 bits) on interface unknown, id 0
▶ Ethernet II, Src: Cisco_14:eb:31 (00:c1:b1:14:eb:31), Dst: Dell_0a:69:f1 (00:19:b9:0a:69:f1)
▶ Internet Protocol Version 4, Src: 172.16.0.1, Dst: 192.168.10.50
▶ Transmission Control Protocol, Src Port: 44634, Dst Port: 80, Seq: 4224, Ack: 7115, Len: 602
▼ Hypertext Transfer Protocol
  ▼ POST /dv/login.php HTTP/1.1\r\n
    Request Method: POST
    Request URI: /dv/login.php
    Request Version: HTTP/1.1
    Host: 205.174.165.68\r\n
    User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0\r\n
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8\r\n
    Accept-Language: en-US,en;q=0.5\r\n
    Accept-Encoding: gzip, deflate\r\n
    Referer: http://205.174.165.68/dv/login.php\r\n
  ▼ Cookie: security=low; PHPSESSID=arvio4k1tk140p62tqvge4enp5\r\n
    Cookie pair: security=low
    Cookie pair: PHPSESSID=arvio4k1tk140p62tqvge4enp5
    Connection: keep-alive\r\n
    Content-Type: application/x-www-form-urlencoded\r\n
  ▼ Content-Length: 130\r\n
    [Content length: 130]
    \r\n
    [Response in frame: 149]
    [Full request URI: http://205.174.165.68/dv/login.php]
    File Data: 130 bytes
  ▼ HTML Form URL Encoded: application/x-www-form-urlencoded
    ▼ Form item: "username" = "admin"
      Key: username
      Value: admin
    ▼ Form item: "password" = "BwBFYP56GIGGNMS5SFZ8TJPZR7S5GHGQSLEKNAF347P5M7A30L"
      Key: password
      Value: BwBFYP56GIGGNMS5SFZ8TJPZR7S5GHGQSLEKNAF347P5M7A30L
    ▼ Form item: "Login" = "Login"
      Key: Login
      Value: Login
    ▼ Form item: "user_token" = "9b76f235eb8bf915159ff91c441b02c3"
      Key: user_token
      Value: 9b76f235eb8bf915159ff91c441b02c3

```

```

0000  00 19 b9 0a 69 f1 00 c1  b1 14 eb 31 08 00 45 00  ...i...1..E.

```

Host: 205.174.165.68
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Cookie: security=low; security=low; PHPSESSID=arvio4k1tk140p62tqvge4enp5
Connection: keep-alive

HTTP/1.1 302 Found
Date: Thu, 06 Jul 2017 12:21:33 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Location: ../../login.php
Content-Length: 0
Keep-Alive: timeout=5, max=76
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

GET /dv/login.php HTTP/1.1
Host: 205.174.165.68
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Cookie: security=low; PHPSESSID=arvio4k1tk140p62tqvge4enp5
Connection: keep-alive

HTTP/1.1 200 OK
Date: Thu, 06 Jul 2017 12:21:33 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 699
Keep-Alive: timeout=5, max=75

20 client pkts, 20 server pkts, 39 turns.

Entire conversation (31 kB)

Show as ASCII

No delta times

```

<div id="header">
<br />
<p></p>
<br />
</div> <!--<div id="header">-->
<div id="content">
<form action="login.php" method="post">
<fieldset>
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />
<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />
<br />
<p class="submit"><input type="submit" value="Login" name="Login"></p>
</fieldset>
<input type='hidden' name='user_token' value='6c1456a7bfab56a9e2699e75578be647' />
</form>
<br />
<br />
<br />
<br />
<br />
20 client pkts, 20 server pkts, 39 turns.

```

Podejrzane źródło IPv4: 172.16.0.1

Cel IPv4: 192.168.10.50

Usługa: HTTP / TCP 80

Endpoint: /dv/login.php

Metoda: POST

Nazwa użytkownika: admin

Charakter ruchu: wielokrotne próby logowania ze zmienianym hasłem

Liczba POST do /dv/login.php: 1344

Hipoteza: web brute force

Poziom pewności: wysoki

Używając filtra:” ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && http.request.method == "POST" && http.request.uri == "/dv/login.php" - notuje numer pierwszej i ostatniej ramki, gdzie występują zdarzenia

według filtra oraz dopisuje czas.

ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && http.request.method == "POST" && http.request.uri == "/dv/login.php"							
No.	Time	Source	Destination	Protocol	Length	Info	
447515	1679.170002	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447572	1680.419625	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447603	1681.681761	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447616	1682.948561	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447641	1684.333124	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447671	1685.591268	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447686	1686.851749	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447708	1688.109981	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447745	1689.365323	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447768	1690.643449	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447785	1691.904937	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447800	1693.171378	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447828	1694.425311	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447853	1695.670827	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447868	1696.943310	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447887	1698.205125	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447916	1699.464496	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447937	1700.723788	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447957	1701.969100	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447972	1703.258987	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
447999	1704.551701	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448018	1705.834293	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448033	1707.091716	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448058	1708.471467	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448080	1709.821355	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448102	1711.083029	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448126	1712.346511	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448141	1713.591297	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448160	1714.897201	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448179	1716.154894	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448202	1717.412636	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
448835	1718.673991	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
449265	1719.924227	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
449666	1721.204810	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
450011	1722.468412	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
450385	1723.734203	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
450609	1724.991534	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
450732	1726.253242	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
450876	1727.524466	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
450921	1728.785382	172.16.0.1	192.168.10.50	HTTP	668	POST	/dv/login.php HTTP/1.1 (application/x-www-form-urlencoded)
Frame 450921: Packet 668 bytes on wire (5344 bits) 668 bytes captured (5344 bits) on interface unknown 0000 00 19 b9 0a 69 f1 00 c1 b1 14 eb 31 08 00 45 00 ... i							
scenario4_small.pcapng Packets: 450985 · Displayed: 1344 (0.3%)							

Zakres czasowy:

1. (pierwsza próba) Frame 24, Time: 1.171969 s
2. (ostatnia próba) Frame 450921, Time: 1728.785382 s

Liczba żądań POST do /dv/login.php: 1344

Wyfiltrowana seria trwała około 1727,61 sekund

Przeglądam szczegółowo ostatnią ramkę numer 450921 tego wyfiltrowanego ataku:

```
Wireshark · Packet 450921 · scenario4_small.pcapng

[!RTT: 692.000 microseconds]
[Bytes in flight: 602]
[Bytes sent since last PSH flag: 602]
[Client Contiguous Streams: 1]
[Server Contiguous Streams: 1]
TCP payload (602 bytes)
▼ Hypertext Transfer Protocol
  ▼ POST /dv/login.php HTTP/1.1\r\n
    Request Method: POST
    Request URI: /dv/login.php
    Request Version: HTTP/1.1
    Host: 205.174.165.68\r\n
    User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:45.0) Gecko/20100101 Firefox/45.0\r\n
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8\r\n
    Accept-Language: en-US,en;q=0.5\r\n
    Accept-Encoding: gzip, deflate\r\n
    Referer: http://205.174.165.68/dv/login.php\r\n
    ▼ Cookie: security=low; PHPSESSID=f4depd7v11s9mhhp6nhk1vaiu3\r\n
      Cookie pair: security=low
      Cookie pair: PHPSESSID=f4depd7v11s9mhhp6nhk1vaiu3
    Connection: keep-alive\r\n
    Content-Type: application/x-www-form-urlencoded\r\n
    ▼ Content-Length: 130\r\n
      [Content length: 130]
    \r\n
    [Response in frame: 450922]
    [Full request URI: http://205.174.165.68/dv/login.php]
    File Data: 130 bytes
  ▼ HTML Form URL Encoded: application/x-www-form-urlencoded
    ▼ Form item: "username" = "admin"
      Key: username
      Value: admin
    ▼ Form item: "password" = "QA3GSMRXT4R1WEMCNYN2BLMX13HTZCC08P6QGK4987WVMSA2QK"
      Key: password
      Value: QA3GSMRXT4R1WEMCNYN2BLMX13HTZCC08P6QGK4987WVMSA2QK
    ▼ Form item: "Login" = "Login"
      Key: Login
      Value: Login
    ▼ Form item: "user_token" = "8f5605aef2389f7cae0b818d48c99a8b"
      Key: user_token
      Value: 8f5605aef2389f7cae0b818d48c99a8b
```

Ostatnia ramka/próba nadal dotyczy, próby zalogowania do konta admin, dodatkowo znowu innym hasłem.

Odwracam teraz kierunek sygnałów, analogicznie do zadania numer 2, aby sprawdzić odpowiedzi z kodem 302 z naszego celu 192.160.10.50:

“ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && http.response.code == 302

“

ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && http.response.code == 302							
No.	Time	Source	Destination	Protocol	Length	Info	
448000	1704.554743	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448013	1705.579429	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448019	1705.837528	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448025	1706.851001	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448034	1707.094714	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448047	1708.107530	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448059	1708.475187	192.168.10.50	172.16.0.1	HTTP	428	HTTP/1.1 302	Found
448075	1709.578773	192.168.10.50	172.16.0.1	HTTP	434	HTTP/1.1 302	Found
448081	1709.824514	192.168.10.50	172.16.0.1	HTTP	428	HTTP/1.1 302	Found
448094	1710.839863	192.168.10.50	172.16.0.1	HTTP	434	HTTP/1.1 302	Found
448103	1711.089288	192.168.10.50	172.16.0.1	HTTP	428	HTTP/1.1 302	Found
448117	1712.103998	192.168.10.50	172.16.0.1	HTTP	436	HTTP/1.1 302	Found
448127	1712.349910	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448133	1713.364388	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448142	1713.594941	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448155	1714.613936	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448161	1714.900336	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448171	1715.911995	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448180	1716.158092	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448189	1717.173171	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448205	1717.415605	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
448297	1718.433948	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
448836	1718.677665	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
449188	1719.693508	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
449282	1719.927337	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
449610	1720.943959	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
449670	1721.208196	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
449998	1722.226162	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
450012	1722.471773	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
450295	1723.492657	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
450387	1723.737380	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
450600	1724.759008	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
450611	1724.995656	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
450670	1726.007995	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
450733	1726.256559	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
450864	1727.273796	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
450877	1727.527592	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
450902	1728.541411	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found
450922	1728.788542	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
450981	1729.807675	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found

Ramka numer 636 ma dłuższy Length od pozostałych. Sprawdź szczegóły.

261	10.266902	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
636	26.858751	192.168.10.50	172.16.0.1	HTTP	578	HTTP/1.1 302	Found
679	28.064332	192.168.10.50	172.16.0.1	HTTP	429	HTTP/1.1 302	Found
747	29.086464	192.168.10.50	172.16.0.1	HTTP	435	HTTP/1.1 302	Found

```
Wireshark · Packet 636 · scenario4_small.pcapng
▶ Frame 636: Packet, 578 bytes on wire (4624 bits), 578 bytes captured (4624 bits) on interface unknown, id 0
▼ Ethernet II, Src: Dell_0a:69:f1 (00:19:b9:0a:69:f1), Dst: Cisco_14:eb:31 (00:c1:b1:14:eb:31)
  ▾ Destination: Cisco_14:eb:31 (00:c1:b1:14:eb:31)
    .... 0. .... = LG bit: Globally unique address (factory default)
    .... 0 .... = IG bit: Individual address (unicast)
  ▶ Source: Dell_0a:69:f1 (00:19:b9:0a:69:f1)
    Type: IPv4 (0x0800)
    [Stream index: 2]
  ▶ Internet Protocol Version 4, Src: 192.168.10.50, Dst: 172.16.0.1
  ▶ Transmission Control Protocol, Src Port: 80, Dst Port: 44884, Seq: 1, Ack: 310, Len: 512
  ▼ Hypertext Transfer Protocol
    ▾ HTTP/1.1 302 Found\r\n
      Response Version: HTTP/1.1
      Status Code: 302
      [Status Code Description: Found]
      Response Phrase: Found
      Date: Thu, 06 Jul 2017 12:21:56 GMT\r\n
      Server: Apache/2.4.18 (Ubuntu)\r\n
      Set-Cookie: PHPSESSID=f4depd7v11s9mhhp6nhk1vaiu3; path=/\r\n
      Expires: Thu, 19 Nov 1981 08:52:00 GMT\r\n
      Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0\r\n
      Pragma: no-cache\r\n
      Set-Cookie: PHPSESSID=f4depd7v11s9mhhp6nhk1vaiu3; path=/\r\n
      Set-Cookie: security=low\r\n
      Location: ../../login.php\r\n
    ▾ Content-Length: 0\r\n
      [Content length: 0]
      Keep-Alive: timeout=5, max=100\r\n
      Connection: Keep-Alive\r\n
      Content-Type: text/html; charset=UTF-8\r\n
      \r\n
      [Request in frame: 634]
      [Time since request: 1.408000 milliseconds]
      [Request URI: /dv/vulnerabilities/xss_r/]
      [Full request URI: http://205.174.165.68/dv/vulnerabilities/xss_r/]
```

Nic nowego z niego nie wynika.

RAPORT Z BADANEGO INCYDENTU:

Zakres materiału

- nazwa i SHA-256 pliku:

scenario4_small.pcapng

SHA-256: bd11962f737f0737ee1ed38b7d37df21088d3d587faa84eadbb94c9c90a1eea3

- Źródło i punkt przechwycenia:

Materiał stanowi zapis ruchu sieciowego z pliku scenario4_small.pcapng - analizowany w programie Wireshark.

W analizowanym zdarzeniu zidentyfikowano komunikację z IPv4 172.16.0.1 do IPv4 192.168.10.50.

Punkt przechwycenia ruchu nie został określony za pomocą otrzymanego pliku .pcap.

- Przedział czasu i strefa:

Pierwsze analizowane żądanie logowania występuje w ramce nr 24 w czasie 1.171969 s, natomiast ostatnie w ramce nr 450921 w czasie 1728.785382 s czasu względnego przechwycenia.

Łącznie trwało to około 1727,61 s, czyli około 28 min 48 s.

Strefa czasowa nie została ustalona.

- Znane ograniczenia:

Analiza została wykonana wyłącznie na podstawie ruchu zapisanego w pliku .pcap. Przez brak porównania z logami systemowymi, serwera WWW, IDS/IPS lub EDR. Dlatego na podstawie samego pliku PCAP nie można jednoznacznie określić procesu odpowiedzialnego za wygenerowanie ruchu ani stwierdzić, czy działanie było autoryzowane.

Podsumowanie

W przechwyconym ruchu zidentyfikowano 1344 żądania HTTP POST wysyłane z 172.16.0.1 do 192.168.10.50 i skierowane do endpointa: /dv/login.php. Analiza zawartości wykazała wielokrotne próby logowania na konto „admin” ze zmieniającymi się wartościami pola „password”, co stanowi charakterystyczny wzorzec ataku web brute force.

Chronologia

Time 1.171969 s | 172.16.0.1:44634 -> 192.168.10.50:80 - ramka nr 24; żądanie HTTP POST /dv/login.php zawierające próbę logowania na konto „admin” z przestany hasłem.

Time 1.175141 s | 192.168.10.50:80 -> 172.16.0.1:44634 - odpowiedź serwera związana z próbą logowania (ramka nr 25).

Time: 1728.785382 s | 172.16.0.1 -> 192.168.10.50:80 - ramka nr 450921; kolejne żądanie POST /dv/login.php dla użytkownika „admin”, zawierające inną wartość pola „password” niż w pierwszej analizowanej próbie.

Time: 1728.788542 s | 192.168.10.50:80 -> 172.16.0.1 - ramka nr 450922; odpowiedź serwera na ostatnią analizowaną próbę logowania.

Dowody

- numer ramki lub strumienia:

Ramka nr 24 – pierwsza analizowana próba logowania

Ramka nr 25 – odpowiedź serwera na ramkę nr 24

Ramka nr 450921 – ostatnia analizowana próba logowania

Ramka nr 450922 – odpowiedź serwera na ramkę nr 450921

- zastosowane filtry:

1. Wyszukanie żądań HTTP POST:

`"http.request.method == "POST"`

2. Zawężenie ruchu do zidentyfikowanego źródła, celu i endpointu logowania:

`"ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && http.request.method == "POST" && http.request.uri == "/dv/login.php"`

3. Analiza odpowiedzi HTTP 302 serwera:

`"ip.src == 192.168.10.50 && ip.dst == 172.16.0.1 && http.response.code == 302"`

4. Zapytania skierowane do endpointu logowania /dv/login.php

`ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && http.request.method == "POST" && http.request.uri == "/dv/login.php"`

- zaobserwowane pola i statystyki:

W Statistics -> Conversations -> IPv4, przy aktywnym filtrze POST, para 172.16.0.1 i 192.168.10.50 wyróżniła się największą liczbą pakietów spełniających warunek filtra. Zarejestrowano 1344 pakiety w kierunku 172.16.0.1 -> 192.168.10.50.

W Statistics -> Endpoints -> IPv4 dla hosta 172.16.0.1 widocznych było 1344 pakietów Tx i 0 Rx spełniających filtr, natomiast dla 192.168.10.50 było 0 Tx i 1344 Rx. Potwierdza to kierunek analizowanych zapytań HTTP POST.

Po zastosowaniu dokładnego filtra:

```
ip.src == 172.16.0.1 && ip.dst == 192.168.10.50 && http.request.method == "POST" && http.request.uri == "/dv/login.php"
```

Wireshark wyświetlił 1344 żądania skierowane do endpointu logowania /dv/login.php.

W ramce nr 24 zaobserwowano:

- metodę POST,
- URI /dv/login.php,
- protokół HTTP/1.1,
- Content-Type: application/x-www-form-urlencoded,
- pole username o wartości „admin”,
- pole password
- pole Login,
- pole user_token

Analiza kolejnych żądań wykazała, że nazwa użytkownika „admin” pozostawała taka sama, natomiast wartości pola „password” zmieniały się pomiędzy próbami. W ramce nr 450921 nadal występowało żądanie POST /dv/login.php dla użytkownika „admin”, ale z inną wartością hasła niż w ramce nr 24.

Analiza HTTP Stream potwierdziła powtarzające się próby logowania oraz odpowiedzi aplikacji wskazujące na nieudane próby, m.in. poprzez przekierowanie do login.php i komunikat „Login failed”.

Ocena:

- hipoteza:

Host 172.16.0.1 wykonywał wielokrotne próby logowania do aplikacji WWW działającej na hoście 192.168.10.50, wykorzystując konto „admin” i zmieniając kolejne wartości hasła. Zaobserwowany wzorec wskazuje na atak typu web brute force.

- alternatywne wyjaśnienie:

Ruch mógł pochodzić z autoryzowanego testu penetracyjnego, automatycznego skanera bezpieczeństwa lub kontrolowanego testu mechanizmu logowania aplikacji.

- poziom pewności:

wysoki

Rekomendowane działania

- korelacja z logami lub EDR:

Skorelować czas wystąpienia zaobserwowanych prób logowania z logami serwera WWW, aplikacji, systemu operacyjnego, firewall-a, IDS/IPS oraz EDR.

- identyfikacja właściciela i procesu:

Ustalić właściciela odpowiedzialnego za ruch z IPv4 172.16.0.1 oraz proces lub aplikację odpowiedzialną za generowanie dużej liczby żądań HTTP POST do /dv/login.php. Zweryfikować, czy aktywność była autoryzowana.

- ewentualna izolacja zgodnie z procedurą IR:

Jeżeli ruch z IPv4 172.16.0.1 nie miał autoryzacji, należy rozważyć ograniczenie komunikacji lub izolację z tego adresu, a nawet potencjalnie i domeny, z której pochodzi, zgodnie z obowiązującymi procedurami. Dodatkowo należy przeprowadzić dalszą analizę źródła oraz zabezpieczyć konto będące celem prób logowania.

[KONIEC RAPORTU]

